Universidad Veracruzana

Facultad de Estadística e Informática

Región Xalapa

Licenciatura en Ingeniería en Ciberseguridad e Infraestructura de Computo

Estado del arte de las medidas de seguridad a nivel de aplicación en el contexto de ataques de inyección de *prompt* dirigidos a sistemas basados en LLM

Presentación de avances para la EE Proyecto Guiado

Presenta:
Abraham Núñez Sánchez

Director:
Héctor Xavier Limón Riaño

Septiembre de 2026

"Lis de Veracruz: Arte, Ciencia, Luz"



Vo. Bo.

Índice

1. Antecedentes 3
2. Planteamiento del Problema 6
3. Pregunta de investigación 8
3.1. Preguntas especificas 8
4. Objetivos 9
4.1. Objetivo General 9
4.2. Objetivos específicos 9
5. Justificación 9
6. Delimitación del trabajo 11
6.1. Alcances 11
6.2. Limitaciones 11
7. Marco teórico 12
7.1. Ciberseguridad 12
7.1.1. Ciberataque 12
7.1.2. Vector de ataque 12
7.1.3. Vulnerabilidad 13
7.1.4. Amenaza 13
7.1.5. Mitigación 13
7.2. Modelos grandes de lenguaje (LLM) 13
7.2.1. Sistemas basados en LLM's 13
7.2.1.1. Prompt 14
7.2.2. Aplicaciones que utilizan LLM's 15
7.2.3. Entrenamiento de LLM's 15
8. Método de la investigación 16
9. Índice tentativo del trabajo de investigación 18
10. Cronograma de actividades 18
11. Referencias 19

1. Antecedentes

En la actualidad, la ciberseguridad se ha consolidado como un área fundamental en el desarrollo y operación de los sistemas digitales modernos, dada la necesidad de proteger la confidencialidad, integridad y disponibilidad de la información, así como reducir los riesgos asociados a vectores de ataque. De acuerdo con *Fortinet* (2026), la Ciberseguridad ya no es solo una función de TI. Es una prioridad principal del negocio. El panorama de amenazas ha cambiado significativamente. Los atacantes son más rápidos, más automatizados y selectivos que nunca.

De acuerdo con el *National Institute of Standards and Technology* (NIST), la ciberseguridad comprende las actividades desarrolladas para prevenir, detectar y responder ante ataques con el propósito de proteger la información y los sistemas que la procesan (NIST, n. d.). Estas actividades buscan preservar propiedades fundamentales de la seguridad de la información, como la confidencialidad, integridad y disponibilidad, frente a amenazas que pueden ocasionar accesos no autorizados, divulgación, modificación, interrupción o destrucción de la información.

La ciberseguridad no solo se orienta a responder a amenazas existentes, sino también a anticipar riesgos, evaluar las vulnerabilidades, cumplir con marcos normativos y fortalecer la seguridad de las organizaciones.

En los últimos años, una de las tendencias en el área de la tecnología es la inteligencia artificial generativa en aplicaciones de uso cotidiano y profesional, en particular, los modelos grandes de lenguaje, LLM por sus siglas en inglés. De acuerdo con IBM (Stryker, 2026), son una categoría de modelos de aprendizaje profundo entrenados con grandes cantidades de datos, lo que les permite comprender y generar lenguaje natural y otros tipos de contenido para realizar diversas tareas.

Por su parte, un sistema basado en LLM puede entenderse como una aplicación o entorno de software que usa un LLM como componente principal para procesar instrucciones y generar respuestas, pero que, además, puede integrar otros elementos, como *prompts* del sistema, entradas del usuario, documentos externos, herramientas, etc. Los LLM han comenzado a

utilizarse en tareas como la generación de texto, análisis de información, asistencia en programación, automatización de procesos, consulta de documentos y apoyo en diversas actividades como el área de la ciberseguridad.

En este sentido, Mirtaheri et al. (2026) analizaron más de 100 publicaciones entre 2021 y 2025 sobre inteligencia artificial generativa aplicada a la evaluación de vulnerabilidades y gestión de riesgos, identificando aplicaciones ofensivas y defensivas, así como retos asociados con la seguridad, la aplicabilidad y la confiabilidad. Esta revisión permite observar que la inteligencia artificial generativa ya forma parte de procesos técnicos relacionados con la ciberseguridad y que su aplicación y uso requieren mecanismos de control, evaluación y aseguramiento.

Dentro de este contexto, uno de los riesgos de seguridad asociados con los sistemas basados en LLM es la inyección de *prompt* o *prompt injection* en inglés. Vassilev et al. (2025) distinguen entre ataques de *direct prompting* y ataques de *direct prompt injection*. Los primeros ocurren cuando el atacante es el usuario principal del sistema e interactúa con el modelo mediante consultas. Dentro de esta categoría, la *direct prompt injection* ocurre cuando el usuario proporciona instrucciones dentro del contexto que son incorporadas junto con instrucciones de mayor nivel de confianza, como las establecidas por el diseñador de la aplicación.

A su vez, Vassilev et al. (2025) describen la inyección indirecta de *prompt (indirect prompt injection*) como un ataque que puede ocurrir cuando un sistema basado en IA generativa interactúa con recursos adicionales, como agentes conectados a Internet. Debido a que los modelos pueden combinar datos e instrucciones dentro de su procesamiento, un atacante puede manipular recursos externos para introducir instrucciones que afecten las operaciones del sistema sin interactuar directamente con la aplicación.

En estos casos, el atacante puede ser un tercero distinto del usuario principal, quien incluso puede convertirse en la persona afectada por el ataque. En ambos tipos de inyección de *prompt*, estas instrucciones pueden buscar que el LLM ignore reglas previas, modifique su respuesta, revele información sensible, ejecute acciones no previstas o favorezca los objetivos del atacante.

Debido al crecimiento de la investigación sobre ataques de inyección de *prompt*, también se han desarrollado revisiones de la literatura orientadas a organizar y analizar el conocimiento existente sobre esta amenaza. Por ejemplo, Duarte et al. (2026) realizan una revisión sistemática centrada específicamente en los ataques de *prompt injection*, en la que analizan su evolución, taxonomías, técnicas de ataque, métodos de evaluación y estrategias de defensa. Los autores señalan que el campo ha evolucionado desde ataques basados en instrucciones de lenguaje natural hasta técnicas más complejas, incluyendo inyecciones indirectas y ataques que utilizan documentos o datos estructurados como fuentes de entrada.

Asimismo, Wang et al. (2026) presentan una sistematización de 78 trabajos sobre ataques y defensas frente a *prompt injection* en agentes basados en LLM. Su propuesta clasifica las defensas de acuerdo con la etapa en la que intervienen, incluyendo los niveles de texto, modelo y ejecución, y además evalúa diferentes mecanismos considerando aspectos como la efectividad frente a los ataques, la utilidad del agente y el costo computacional.

Dentro de esta clasificación, las medidas de seguridad pueden intervenir en distintos componentes y etapas de un sistema basado en LLM. En particular, las medidas implementadas a nivel de aplicación corresponden a controles aplicados sobre la aplicación o plataforma que integra el modelo, sin requerir modificaciones en el entrenamiento o en la arquitectura interna del LLM.

En este nivel pueden considerarse mecanismos relacionados con el procesamiento de entradas, la construcción de *prompts*, la detección de contenido malicioso, la validación de salidas, el control de herramientas, el monitoreo, el registro de actividad y la evaluación de las medidas de seguridad.

Por lo tanto, las revisiones sistemáticas existentes permiten observar un panorama amplio de los ataques de inyección de *prompt* dirigidos a modelos LLM y de las diferentes medidas propuestas para mitigarlos. Estas revisiones abarcan distintos niveles de intervención, desde medidas que modifican el propio modelo, como el ajuste o entrenamiento, hasta aquellas que se implementan de manera externa al LLM, sin modificar directamente su comportamiento.

En este contexto, resulta destacable delimitar el análisis a las medidas de seguridad implementadas a nivel de aplicación, es decir, aquellas que actúan sobre los componentes que integran y rodean al LLM sin modificar su entrenamiento ni su arquitectura interna.

2. Planteamiento del Problema

En los sistemas basados en LLM, las instrucciones y los datos pueden ser procesados dentro de un mismo contexto de lenguaje natural. Esta característica permite que una instrucción maliciosa sea introducida directamente mediante el *prompt* proporcionado por el usuario o indirectamente a través de documentos, páginas web u otras fuentes externas procesadas por el sistema.

Greshake et al. (2023) muestran que esta integración puede difuminar la separación entre datos e instrucciones, permitiendo que contenido modificado por un atacante sea incorporado al contexto utilizado durante la inferencia. En consecuencia, una inyección de *prompt* puede alterar el comportamiento esperado del sistema y, dependiendo de las capacidades de la aplicación, provocar respuestas manipuladas, extracción de información, incumplimiento de instrucciones o acciones no previstas.

Las investigaciones previas también permiten observar que se trata de un problema extendido dentro del campo de seguridad de los LLM. Por ejemplo, Geng et al. (2026), mediante una revisión sistemática basada en las directrices de Kitchenham, analizaron 128 estudios revisados por pares publicados entre 2022 y 2025 e identificaron 37 enfoques de defensa frente a ataques de inyección de *prompt*. La revisión reporta que los ataques evaluados pueden superar el 90% de éxito en sistemas sin protección, mientras que las medidas de preprocesamiento de entradas presentan tasas de detección de aproximadamente 60% a 80% y algunas defensas arquitectónicas alcanzan hasta un 95% de protección frente a patrones conocidos.

Sin embargo, los autores también señalan que estas medidas presentan limitaciones frente a vectores de ataque novedosos y que todavía existen deficiencias en los marcos estandarizados para evaluar su efectividad.

Desde una perspectiva de organización de la información y el conocimiento, existen trabajos al respecto, por ejemplo, Kumar et al. (2024) presentan un marco que clasifica diversos

ataques de inyección de *prompt* según el tipo utilizado en los ataques, el tipo de límite de confianza que violaron los ataques y el nivel de experiencia requerido para llevarlos a cabo. El análisis de este marco da lugar a recomendaciones sobre cómo se podrían fortalecer aún más los límites de confianza mediante una combinación de enfoques sociotécnicos.

De manera complementaria, Mathew E.S. (2025) explora métodos avanzados para inducir a los modelos de lenguaje grandes a generar comportamientos inapropiados mediante ataques de inyección de *prompts* que obligan a los LLM a producir respuestas afirmativas a consultas dañinas. Asimismo, evaluó el desempeño de los LLM frente a estos ataques y propone un marco de clasificación sistémico que analiza diversos tipos de ataques de inyección de *prompts* y sus defensas.

O el mismo Wang et al. (2026) sistematizaron 78 trabajos relacionados con ataques y defensas en agentes basados en LLM y clasificaron las defensas según su etapa de intervención: texto, modelo y ejecución. Sus resultados muestran que las medidas de seguridad pueden presentar compromisos entre confiabilidad, utilidad y latencia, especialmente en tareas dependientes del contexto, donde bloquear o suprimir información puede reducir la capacidad funcional del sistema.

Esta diversidad sugiere que el problema de seguridad no se limita a determinar si una defensa específica puede bloquear un ataque. Las medidas propuestas intervienen en diferentes partes del sistema, utilizan mecanismos distintos y son evaluadas mediante criterios que pueden considerar la tasa de detección o éxito del ataque, la utilidad de las respuestas, el costo computacional, la latencia, la capacidad de generalización frente a ataques nuevos y el riesgo residual.

Por ello, una medida que presenta buenos resultados en un escenario determinado no necesariamente ofrece el mismo nivel de protección cuando se utiliza en otro contexto o ante otro tipo de inyección.

En consecuencia, el problema de investigación no consiste en la ausencia de propuestas de seguridad frente a la inyección de *prompt*, sino en la dispersión y generalidad del

conocimiento existente sobre dichas propuestas, particularmente cuando se consideran aquellas que pueden implementarse a nivel de aplicación.

La literatura incluye medidas que actúan sobre las entradas, el procesamiento del contexto, la detección de contenido malicioso, las salidas generadas, el acceso a herramientas o recursos externos y la supervisión de las acciones del sistema, pero estas propuestas aparecen en estudios con diferentes objetivos, escenarios y métodos de evaluación. A su vez, otras investigaciones se concentran en modificar o adaptar el propio modelo, por ejemplo, mediante entrenamiento o ajuste, lo que corresponde a un nivel de intervención distinto.

Considerando lo anterior, resulta necesario delimitar y organizar la evidencia disponible sobre las medidas de seguridad que pueden implementarse a nivel de aplicación, sin modificar su entrenamiento ni la arquitectura interna del LLM.

3. Pregunta de investigación

¿Qué medidas de seguridad a nivel de aplicación han sido propuestas y evaluadas frente a los ataques de inyección de *prompt* en sistemas basados en LLM, y cuáles son sus principales características, alcances, limitaciones y criterios de evaluación?

3.1. Preguntas especificas

I. ¿Qué es un ataque de inyección de *prompt* y cuáles son las categorías que presenta?
II. ¿Qué medidas de seguridad a nivel de aplicación han sido propuestas en la literatura reciente para reducir los ataques de inyección de *prompt* en sistemas basados en LLM?
III. ¿Cómo pueden clasificarse las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema basado en LLM?
IV. ¿En qué contextos y escenarios han sido evaluadas las medidas identificadas, qué tipos de ataques abordan y qué criterios se utilizan para determinar su efectividad?
V. ¿Qué limitaciones y compromisos entre seguridad, utilidad, rendimiento, costo o complejidad de implementación han sido reportados para las medidas analizadas?
VI. ¿Qué cosas permanecen abiertas o insuficientemente en la literatura sobre medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt*?

4. Objetivos

4.1. Objetivo General

Analizar las medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt* en sistemas basados en LLM, mediante la revisión, clasificación, comparación y síntesis de literatura científica reciente, con el propósito de identificar sus características, contextos de aplicación, alcances, limitaciones y criterios de evaluación.

4.2. Objetivos específicos

I. Identificar los ataques de inyección de *prompt* que pueden ser mitigados desde el lado de la aplicación.

II. Analizar las medidas de seguridad a nivel de aplicación propuestas en la literatura reciente para mitigar los ataques de inyección de *prompt* en sistemas basados en LLM.

III. Clasificar las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema.

IV. Identificar las taxonomías existentes para clasificar las mitigaciones de ataques de inyección de *prompt* a nivel de aplicación.

V. Analizar las formas en las que se evalúan las medidas de seguridad reportadas en la literatura considerando los tipos de ataques abordados, contextos de aplicación, criterios de evaluación, efectividad, impacto sobre la utilidad y limitaciones.

VI. Discutir los alcances y limitaciones que permanezcan abiertos para futuras investigaciones.

5. Justificación

La incorporación de modelos de lenguaje de gran escala en aplicaciones y servicios digitales ha permitido desarrollar sistemas capaces de generar contenido, analizar información, consultar documentos, interactuar con herramientas y automatizar diferentes tareas.

Sin embargo, esta integración también introduce nuevos riesgos de seguridad, entre ellos los ataques de inyección de *prompt*, mediante los cuales instrucciones maliciosas pueden ser incorporadas directamente por un usuario o indirectamente mediante fuentes externas procesadas por el sistema. La literatura reciente ha demostrado la existencia de estos ataques

en diferentes modelos, tareas y escenarios, así como la propuesta de diversas medidas para reducir sus efectos.

A pesar de la existencia de estas propuestas, la información disponible se encuentra distribuida entre estudios que utilizan diferentes escenarios de aplicación, mecanismos de protección y criterios para evaluar su efectividad. Además, las medidas de seguridad pueden intervenir en diferentes componentes del sistema y presentar compromisos entre seguridad, utilidad, rendimiento, costo y complejidad de implementación. Esta diversidad dificulta obtener una visión organizada de las medidas que pueden aplicarse a nivel de aplicación sin modificar el entrenamiento ni la arquitectura interna del LLM.

Por lo anterior, resulta relevante realizar un estado del arte que permita identificar, clasificar, comparar y sintetizar las medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt* en sistemas basados en LLM. Este análisis permitirá reunir la evidencia disponible sobre sus mecanismos de funcionamiento, contextos de aplicación, tipos de ataques abordados, criterios utilizados para su evaluación y principales limitaciones. Asimismo, permitirá identificar aspectos que permanezcan abiertos en la literatura y que puedan orientar futuras investigaciones.

Los resultados pueden beneficiar principalmente a investigadores interesados en la seguridad de sistemas basados en LLM, al proporcionar una síntesis organizada de la literatura reciente que facilite la identificación de líneas de investigación y áreas pendientes. También pueden ser de utilidad para perfiles de administración y gestión de ciberseguridad, quienes pueden emplear esta información como referencia al evaluar riesgos y medidas de protección relacionadas con la incorporación de sistemas basados en LLM dentro de una organización.

De manera complementaria, los resultados pueden ser útiles para perfiles de desarrollo y arquitectura de software, al proporcionar una visión de las diferentes alternativas de seguridad que pueden incorporarse en los componentes que rodean al LLM, así como de sus posibles efectos sobre la utilidad, rendimiento y complejidad del sistema. De esta manera, el trabajo busca contribuir a una mejor comprensión y organización del conocimiento disponible sobre las medidas de seguridad a nivel de aplicación frente a los ataques de inyección de *prompt*.

El análisis de estas medidas permitirá identificar cómo han sido propuestas y evaluadas, qué tipos de ataques y escenarios cubren, cuáles son sus alcances y limitaciones, y qué compromisos presentan entre seguridad y utilidad.

6. Delimitación del trabajo

6.1. Alcances

La investigación tendrá un alcance de tipo descriptivo a partir de literatura científica y académica reciente, considerando publicaciones que estén en el idioma inglés y que sean correspondientes a los últimos cinco años, además, que sean accesibles en motores de búsqueda con acceso institucional como ACM, *Springer*, *ScienceDirect* e IEEE.

La investigación se centrará en el área de la ciberseguridad, buscando lo relacionado a los ataques de inyección de *prompt*, se realizará una recopilación y análisis de las medidas de seguridad que pueden implementarse a nivel de aplicación para hacer frente a dichos ataques. Estas medidas comprenderán aquellas que puedan implementarse mediante componentes o mecanismos externos al modelo reportados en la literatura.

Las medidas recopiladas serán clasificadas de acuerdo con el contexto o punto de intervención dentro del sistema, identificando sus principales características y formas de funcionamiento. Además, se analizarán los criterios y metodologías empleados para evaluar su efectividad, así como los escenarios y tipos de ataques frente a los cuales han sido estudiadas. Finalmente, se sintetizarán los principales alcances, limitaciones y compromisos reportados en la literatura, considerando aspectos como efectividad, utilidad, latencia y capacidad de respuesta ante diferentes escenarios de ataque.

6.2. Limitaciones

En cuanto a las limitaciones, la principal limitación será no usar artículos o revisiones que no puedas ser accedidos u obtenidos por medios institucionales, además, la investigación se restringirá a las medidas de seguridad implementables a nivel de aplicación, por lo que no se considerarán como parte del análisis aquellas estrategias que requieran modificar el entrenamiento o la arquitectura interna del LLM.

Por último, la investigación no pretende determinar cuál es la medida de seguridad más adecuada o establecer una mitigación como superior a las demás, debido a que el trabajo se desarrollará como un estado del arte basado en evidencia publicada y no contempla la implementación ni la experimentación directa de las medidas identificadas. Por lo tanto, las conclusiones se limitarán a sintetizar y comparar los resultados reportados por las investigaciones revisadas, considerando sus respectivos escenarios, criterios de evaluación, alcances y limitaciones.

7. Marco teórico

7.1. Ciberseguridad

Martin et al. (2021) definen en su marco "*CyBOK*" a la ciberseguridad como la protección de los sistemas de información, incluyendo el hardware, software y la infraestructura asociada, así como de los datos y servicios que proporcionan, frente al acceso no autorizado, daño o uso indebido. Esta protección contempla tanto acciones intencionales como afectaciones accidentales derivadas del incumplimiento de procedimientos de seguridad. El *CyBOK* señala además que la ciberseguridad comprende controles que involucran personas, procesos y tecnología, orientados a prevenir, detectar y responder ante resultados adversos.

7.1.1. Ciberataque

Un ciberataque es cualquier esfuerzo intencional para robar, exponer, alterar, deshabilitar o destruir datos, aplicaciones u otros activos a través del acceso no autorizado a una red informática, sistema informático o dispositivo digital (IBM, 2026). Los ciberataques pueden ser realizados por hackers solitarios hasta delincuentes cibernéticos organizados. Abarcan tácticas como ataques de *malware*, estafas mediante ingeniería social, explotaciones de día cero, etc.

7.1.2. Vector de ataque

Fortinet (n.d.) define un vector de ataque como la ruta o método utilizado por un actor malicioso para acceder ilegalmente a una red o computadora en un intento de explotar las vulnerabilidades del sistema. Los vectores de ataques más habituales se encuentran ataques de ingeniería social, robo de credenciales, explotación de vulnerabilidades, entre otras complementa *Cloudflare* (n.d.). Es importante que la ciberseguridad pueda cerrar los vectores de ataque siempre que sea posible.

7.1.3. Vulnerabilidad

El *CyBOK* proporciona una definición de vulnerabilidad describiendo como aquello que está expuesto a un ataque o uso indebido y que podría conducir a un resultado no deseado. Si es explotada, puede producir un impacto sobre un proceso o sistema. El documento enfatiza además que las vulnerabilidades pueden ser tecnológicas, humanas o incluso legales, por lo que tienen un carácter sociotécnico (Martin et al., 2021).

7.1.4. Amenaza

Dentro del *CyBOK* se define como cualquier individuo, evento o acción que posee la capacidad de explotar una vulnerabilidad. Además, se hace una diferencia entre vulnerabilidad y amenaza: una vulnerabilidad constituye la condición que puede ser explotada, mientras que la amenaza representa aquello que puede realizar dicha explotación (Martin et al., 2021).

7.1.5. Mitigación

Se aborda en el *CyBOK* a las mitigaciones como el apartado de la gestión de riesgos y de la respuesta ante ataques e incidentes. Una mitigación es una medida, técnica o control destinado a reducir la probabilidad de explotación de una vulnerabilidad o a disminuir las consecuencias de un ataque. Entre las medidas consideradas se encuentra acciones destinadas a bloquear amenazas, reducir sus efectos, limitar privilegios, modificar configuraciones y aplicar controles preventivos o reactivos. Mientras el NIST, por su parte, presenta las mitigaciones como métodos destinados a reducir la vulnerabilidad de los sistemas de IA frente a ataques y a gestionar sus consecuencias (Martin et al., 2021; Vassilev et al., 2025).

7.2. Modelos grandes de lenguaje (LLM)

Cloudflare (n.d.) explica que un modelo grande de lenguaje, *large lenguage model* en inglés, es un tipo de programa de inteligencia artificial que puede reconocer y generar texto, entre otras tareas. Los LLM se entrenan con enormes conjuntos de datos. Es decir, un LLM es un programa informático al que se le han incorporado suficientes ejemplos como para poder reconocer e interpretar el lenguaje humano u otros tipos de datos complejos. Además, explica que muchos LLM se entrenan con datos recopilados de Internet.

7.2.1. Sistemas basados en LLM's

NIST señala que los LLM pueden integrarse en aplicaciones de software y combinarse con bases de datos, documentos y herramientas externas. Un sistema basado en LLM es un

sistema de software que integra un modelo de lenguaje como uno de sus componentes que puede incorporar elementos adicionales, como aplicaciones, fuentes de datos, API's, herramientas y otros componentes de procesamiento (Vassilev et al., 2025).

7.2.1.1. Prompt

NIST explica que el comportamiento de un LLM puede ser condicionado mediante instrucciones, o *prompts* en inglés, proporcionadas por desarrolladores o usuarios pueden incorporarse al contexto del modelo que orientan a los LLM hacia un caso de uso determinado (Vassilev et al., 2025). En una aplicación puede existir un *prompt* del sistema, construido por el desarrollador de la aplicación, que posee un nivel de confianza superior al de otras entradas.

También se refiere al input como la información que recibe el modelo durante su interacción con el usuario, contexto, documentos u otras fuentes. En términos generales la información proporcionada a un LLM o sistema basado en LLM para su procesamiento, la cual puede proceder directamente del usuario o de otras fuentes incorporadas al contexto del sistema (Vassilev et al., 2025).

El input no necesariamente equivale solamente al mensaje escrito por el usuario. En un sistema basado en LLM puede incluir instrucciones del sistema, información de herramientas y otros datos.

Mientras el output es el resultado generado por el LLM a partir del input y del contexto disponible, que posteriormente puede ser presentado al usuario o utilizado por otros componentes de la aplicación. El NIST utiliza output para referirse al contenido generado por el modelo como resultado de su procesamiento. En los sistemas basados en LLM, este resultado puede ser mostrado directamente al usuario o procesado posteriormente por la aplicación. El documento advierte que cuando el output se utiliza dinámicamente, por ejemplo, para construir un comando que posteriormente se ejecuta, puede generar riesgos de disponibilidad, integridad o privacidad (Vassilev et al., 2025).

Por último, el NIST define *prompt injection* como un ataque que explota la concatenación de una entrada no confiable con un *prompt* construido por una parte con mayor nivel de confianza, como el diseñador de la aplicación. El documento explica que, durante el procesamiento, las instrucciones proporcionadas por el desarrollador o usuario pueden ser incorporadas al contexto del modelo. Una inyección de *prompt* puede aprovechar la combinación entre las instrucciones de mayor confianza y las entradas no confiables para inducir un comportamiento no previsto (Vassilev et al., 2025).

NIST distingue además entre:

- Inyección directa: La entrada maliciosa es proporcionada directamente al sistema por el usuario o atacante. NIST incluye dentro de los ataques de *prompting* directo diversas técnicas destinadas a modificar el comportamiento del LLM.
- Inyección indirecta: La instrucción maliciosa procede de una fuente externa que posteriormente es incorporada al contexto del modelo. NIST la define como un tipo de *prompt injection* ejecutado mediante el control de recursos externos, en lugar de introducirse directamente como entrada del usuario.

7.2.2. Aplicaciones que utilizan LLM's

En el contexto específico de los LLM, NIST muestra que estos modelos pueden estar integrados dentro de aplicaciones que proporcionan acceso a datos externos, herramientas y otros servicios. Una aplicación, en el contexto de sistemas basados en LLM, es el componente de software que integra y utiliza el modelo para proporcionar una funcionalidad específica, pudiendo encargarse de la construcción de instrucciones, procesamiento de entradas, gestión de contexto, tratamiento de resultados y acceso a recursos externos.

7.2.3. Entrenamiento de LLM's

NIST define la etapa de entrenamiento como aquella fase del ciclo de aprendizaje automático en la que el modelo aprende parámetros destinados a minimizar su error respecto de una función objetivo utilizando datos de entrenamiento. Para los modelos de IA generativa, esta etapa suele comprender el preentrenamiento de un modelo fundacional y el ajuste del modelo para tareas específicas (Vassilev et al., 2025).

El preentrenamiento permite que el modelo aprenda patrones, características y relaciones generales a partir de grandes cantidades de datos, mientras que el ajuste del modelo adapta un modelo previamente entrenado para tareas o dominios específicos (Vassilev et al., 2025).

8. Método de la investigación

Kitchenham B. y Charters S. M. (2007) presenta una guía técnica detallada sobre la realización de revisiones sistemáticas de literatura específicamente adaptadas al campo de la ingeniería de software. A diferencia de las revisiones convencionales, este método busca minimizar el sesgo mediante protocolos predefinidos, estrategias de búsqueda auditables y criterios estrictos de inclusión de estudios. Define a la revisión sistemática de literatura como una forma de identificar, evaluar e interpretar la mayor cantidad de información disponible y relevante sobre un tema, cuestión o fenómeno de interés. Los estudios individuales que contribuyen a la revisión sistemática son llamados estudios primarios; una revisión sistemática son una forma de estudio secundario.

Las razones por las que se debe de realizar una revisión sistemática de literatura:

- Resumir la evidencia existente sobre la tecnología, por ejemplo, explorando beneficios y límites.
- Identificar brechas de la investigación actual para futuras investigaciones.
- Proporcionar un contexto o marco para posicionar las actividades de investigación.

Las principales etapas de la revisión sistemática son: planificación de la revisión, la realización de la revisión y la presentación de la revisión.

- Planificación de la revisión: Las actividades previas más importantes son definir las preguntas de investigación que abordará la revisión sistemática y elaborar un protocolo de revisión que defina los procedimientos básicos de la revisión. El protocolo de revisión también debe someterse a un proceso de evaluación independiente.
    - Identificación de la necesidad de una revisión: Confirmar la necesidad de resumir la información existente sobre un tema de manera exhaustiva y no sesgada.

    - Especificación de la(s) pregunta(s) de investigación: Formular las preguntas de investigación que guiaran las estrategias de búsqueda, extracción y síntesis de datos.
    - Desarrollo del protocolo de revisión: Diseñar un plan detallado con los procedimientos a seguir para reducir el sesgo de los investigadores.
    - Evaluación del protocolo de revisión: (Opcional) Someter el protocolo a una revisión independiente para verificar su consistencia interna y rigor metodológico.
- Realización de la revisión: Se siguen los pasos descritos en la sección de elaboración del protocolo.
    - Identificación de la investigación: Ejecutar una estrategia de búsqueda imparcial y rigurosa en bases de datos y otras fuentes para detectar la mayor cantidad posible de estudios primarios.
    - Selección de estudios primarios: Aplicar criterios explícitos de inclusión y exclusión para evaluar cuáles estudios identificados responden directamente a la pregunta de investigación.
    - Evaluación de la calidad de los estudios: Valorar el rigor y la validez de los estudios primarios para ponderar o clasificar sus hallazgos.
    - Extracción de datos: Diseñar y completar formularios estandarizados para registrar la información necesaria de cada estudio seleccionado.
    - Síntesis de datos: Colacionar y resumir los resultados de los estudios, ya sea de forma descriptiva/narrativa o mediante métodos cuantitativos (metaanálisis).
- Presentación de la revisión: Redactar los resultados de la revisión y difundirlos.
    - Especificación de la estrategia de difusión: Definir cómo y a través de qué medios se comunicarán los resultados (revistas académicas, conferencias, informes para la industria, etc.).
    - Formato del informe principal: Redactar los hallazgos en informes técnicos, tesis o publicaciones científicas respetando las estructuras estándar.
    - Evaluación del informe: (Opcional) Organizar revisiones por pares o evaluaciones externas para validar el informe final.

9. Índice tentativo del trabajo de investigación

1. Introducción

1.1. Antecedentes

1.2. Definición del problema

1.3. Objetivos

1.3.1. Objetivo general

1.3.2. Objetivos específicos

1.4. Justificación

1.5. Delimitación del proyecto

1.5.1. Alcance

1.5.2. Limitación

2. Marco teórico

2.1. Ciberseguridad

2.1.1. Ciberataque

2.1.2. Vector de ataque

2.1.3. Vulnerabilidad

2.1.4. Amenaza

2.1.5. Mitigación

2.2. LLM

2.2.1. Sistema basado en LLM

2.2.1.1. Aplicación basada en LLM's

2.2.1.2. *Prompt*

2.2.2. Entrenamiento de LLM

3. Método de investigación

4. Resultados

4.1. Cuantitativos

4.2. Cualitativos

5. Discusión

6. Amenazas a la validez

7. Conclusiones y trabajo futuro

10. Cronograma de actividades

Actividades	Meses																
	2026					2027											
	Agosto	Septiembre	Octubre	Noviembre	Diciembre	Enero	Febrero	Marzo	Abril	Mayo	Junio	Julio	Agosto	Septiembre	Octubre	Noviembre	Diciembre
Protocolo de investigación																	
Protocolo de la revisión																	
Selección de cadena de búsqueda																	
Selección de estudios primarios																	
Extracción de datos																	
Síntesis narrativa																	
Reporte de la revisión																	
Concentrarse en una o dos fuentes de información																	
Explorar más fuentes y snowballing																	
Ampliar selección de estudios																	
Realizar extracción de nuevos estudios																	
Realizar síntesis sistematica																	
Escribir un borrardor de articulo																	
Desarrollo de marco teórico																	
Definición de la discusión																	
Definición de la conclusión																	
Trabajo futuro																	

11. Referencias

1. ¿Qué es la ciberseguridad? Tipos, amenazas y mejores prácticas | Fortinet. (n.d.). Fortinet. https://www.fortinet.com/lat/resources/cyberglossary/what-is-cybersecurity
2. CSRC Content Editor. (n.d.). cybersecurity - Glossary | CSRC. https://csrc.nist.gov/glossary/term/cybersecurity
3. ¿Qué son los LLM? | IBM. (2026, August 16). https://www.ibm.com/mx-es/think/topics/large-language-models
4. Mirtaheri, S. L., Movahed, N., Shahbazian, R., Pascucci, V., & Pugliese, A. (2026). Cybersecurity in the age of generative AI: A systematic taxonomy of AI-powered vulnerability assessment and risk management. Future Generation Computer Systems, 175. https://doi.org/10.1016/j.future.2025.108107
5. Vassilev, A. (2025). Adversarial Machine Learning: https://doi.org/10.6028/NIST.AI.100-2e2025
6. Damacena Duarte, J., Cândido, G. D., de Britto Filho, J. R. A., Souza Neto, J., da Costa, E. J., da Costa, J. P. J., & Peotta De Melo, L. (2026). A Systematic Review of Prompt Injection Attacks on Large Language Models: Trends, Taxonomy, Evaluation, Defenses, and Opportunities. In IEEE Access (Vol. 14, pp. 12875–12899). Institute of Electrical and Electronics Engineers Inc. https://doi.org/10.1109/ACCESS.2026.3656849
7. Wang, P., Li, X., Xiang, C., Zhang, J., Li, Y., Zhang, L., Wang, X., & Tian, Y. (2026). The Landscape of Prompt Injection Threats in LLM Agents: From Taxonomy to Analysis. http://arxiv.org/abs/2602.10453
8. Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. http://arxiv.org/abs/2302.12173
9. Geng, T., Xu, Z., Qu, Y., & Wong, W. E. (2026). Prompt Injection Attacks on Large Language Models: A Survey of Attack Methods, Root Causes, and Defense Strategies. In Computers, Materials and Continua (Vol. 87, Issue 1). Tech Science Press. https://doi.org/10.32604/cmc.2025.074081
10. Kumar, S. S., Cummings, M. L., & Stimpson, A. (2024). Strengthening LLM Trust Boundaries: A Survey of Prompt Injection Attacks Surender Suresh Kumar Dr. M.L. Cummings Dr. Alexander Stimpson. 2024 IEEE 4th International Conference on Human-Machine Systems, ICHMS 2024. https://doi.org/10.1109/ICHMS59971.2024.10555871
11. Mathew, E. S. (2025). Enhancing Security in Large Language Models: A Comprehensive Review of Prompt Injection Attacks and Defenses. Journal on Artificial Intelligence, 7(1), 347–363. https://doi.org/10.32604/jai.2025.069841
12. Martin, A., Schneider, S., Rigby, Y., & Hallett, J. (n.d.). *The Cyber Security Body of Knowledge*. Retrieved www.cybok.org

13. Jonker, T. K. A. (2026, May 22). *¿Qué es un ciberataque?* IBM. https://www.ibm.com/mx-es/think/topics/cyber-attack
14. ¿Qué es un vector de ataque? Tipos y cómo evitarlos | Fortinet. (n.d.). Fortinet. https://www.fortinet.com/lat/resources/cyberglossary/attack-vector
15. ¿Qué es un vector de ataque? | Cloudflare. (n.d.). https://www.cloudflare.com/es-es/learning/security/glossary/attack-vector/

“Lis de Veracruz: Arte, Ciencia, Luz”

www.uv.mx

